

الوحدة 13: المصادقة وإدارة الهوية (IAM)

أنواع المصادقة (Authentication Types)

- Something You Know:** كلمة المرور (Password) أو PIN. الأكثر شيوعاً ولكن الأقل أماناً.
- Something You Have:** شيء مادي تملكه مثل بطاقة ذكية (Smart Card)، توكن (Token)، أو هاتف محمول.
- Something You Are:** قياسات حيوية (Biometrics) مثل بصمة الإصبع، التعرف على الوجه، أو قزحية العين.
- Somewhere You Are:** الموقع الجغرافي (مثل GPS أو عنوان IP).
- Something You Do:** سلوك المستخدم مثل نمط الكتابة على لوحة المفاتيح.

MFA (المصادقة متعددة العوامل)

- مزيج من عاملين أو أكثر من فئات مختلفة (مثلاً: كلمة مرور + بصمة إصبع).
- TOTP (Time-based One-Time Password):** كلمة مرور مرة واحدة تتغير كل 30 ثانية. مثال: Google Authenticator، Authy.
- FIDO2:** معيار للمصادقة بدون كلمة مرور (Passwordless) باستخدام مفاتيح (YubiKey USB) أو Windows Hello. يعتمد على تشفير المفتاح العام/الخاص.

مثال: إنشاء مفتاح SSH عام/خاص

```
ssh-keygen -t rsa -b 4096 -C "myemail@example.com"
```

الشرح جزءاً جزءاً:

- `ssh-keygen` أداة إنشاء مفاتيح SSH.
- `t rsa` يحدد نوع الخوارزمية (RSA).
- `b 4096` يحدد طول المفتاح (4096 بت).
- `-C "..."` يضيف تعليقاً للتعريف بالمفتاح (عادة البريد الإلكتروني).
- ينتج ملفين: `id_rsa` (مفتاح خاص - سري) و `id_rsa.pub` (مفتاح عام - يوزع على الخوادم).

RADIUS، LDAP، Kerberos

- RADIUS (Remote Authentication Dial-In User Service):** بروتوكول للمصادقة المركزية والتفويض والمحاسبة (AAA). يستخدم في الشبكات (VPN، Wi-Fi). يعمل على المنفذ 1812 (مصادقة) و 1813 (محاسبة).
- LDAP (Lightweight Directory Access Protocol):** بروتوكول للوصول إلى دليل المستخدمين (Directory Service) مثل Active Directory. يستخدم للبحث عن المستخدمين والمجموعات والمصادقة.
- Kerberos:** بروتوكول مصادقة موحد (SSO) يستخدم في Windows Active Directory. يعتمد على Tickets الصادرة عن KDC (Key

مثال: عرض مستخدمي Windows المحليين

```
net user
```

الشرح: يعرض قائمة بجميع حسابات المستخدمين المحليين في نظام Windows. استخدمه لمراجعة الحسابات النشطة واكتشاف أي حسابات غير مصرح بها.

مثال: استعلام (Active Directory (PowerShell

```
Get-ADUser -Filter * -Properties LastLogonDate,Enabled | Select-Object Name,SamAccountName
```

الشرح جزءاً جزءاً:

`Get-ADUser -Filter *` يجلب جميع المستخدمين من Active Directory. `-Properties LastLogonDate,Enabled-` يطلب خصائص إضافية. `Select-Object ...` يعرض أعمدة محددة: الاسم، اسم الحساب، آخر تسجيل دخول، حالة التنفيع. مفيد لمراجعة حسابات المستخدمين واكتشاف الحسابات غير النشطة التي يجب تعطيلها.

Federation / SAML / OAuth

Federation (توحيد الهوية): ربط أنظمة هوية مختلفة عبر مؤسسات متعددة. يسمح للمستخدم باستخدام هويته للوصول إلى تطبيقات في مؤسسات أخرى.

(SAML (Security Assertion Markup Language): معيار قائم على XML لتبادل بيانات المصادقة والتفويض بين مزود الهوية (IdP) ومزود الخدمة (SP).

OAuth 2.0: بروتوكول تفويض (Authorization) يسمح لتطبيق بالوصول إلى موارد مستخدم دون مشاركة كلمة المرور. مثال: "تسجيل الدخول باستخدام Google".

(Quick Quiz (MCQ

1. Which authentication factor uses something you have ?

- a) Password
- b) Hardware token
- c) Fingerprint
- d) Knowledge

Answer: b

.2 :FIDO2 is used for

- a) Password storage only
- b) Passwordless authentication
- c) File encryption
- d) VPN configuration

Answer: b

.3 :The `net user` command on Windows is used to

- a) View Active Directory objects
- b) Manage local user accounts
- c) View Linux users
- d) Change network settings

Answer: b

.4 ?Which protocol uses tickets for user authentication

- a) RADIUS
- b) LDAP
- c) Kerberos
- d) SAML

Answer: c

.5 :SAML is primarily used for

- a) Encryption
- b) Federated identity and SSO
- c) Packet filtering
- d) File backup

Answer: b